

CWE AI Working Group: New Entry Development

Meeting Minutes

May 23, 2025

Attendance

Bob Heinemann	Erick Galinkin	Raymond Pompon
Chris Coffin	Monika Akbar	Caroline Rocha
Kyle Norland	Joshua Windle	Sven Cattell
Steve Christey	Michael Simon	Trent Holmes

Agenda

- Status Updates
- New Entry Development: ES2406-9e5fcf10, Insecure Setting of Generative AI/ML Model Inference Parameters

Meeting Notes:

Status Updates

Steve asked participants if there were any new attendees, and Joshua Windle, a master's student at the University of Hamburg with an interest in Linux and AI, introduced himself.

Separately, the group came to a consensus on Chris Madden presenting to the wider CWE AI Working Group on chatbots for CWE AI Mapping.

New Entry Development: ES2406-9e5fcf10, Insecure Setting of Generative AI/ML Model Inference Parameters

Detection Methods Worksheet

A significant portion of the discussion focused on how to detect insecure hyperparameter usage. Participants emphasized both manual and automated dynamic analysis as the primary detection strategies. While specific tool names are

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

typically avoided in CWE entries, Garak was discussed as a useful reference point by Erick due to its suite of prompt injection evaluations and related functionality. Sven noted that Garak might not directly perform the desired dynamic analysis, but its capabilities are still relevant to the security context.

Eric described how package hallucination can be used as a proxy for detecting insecure inference parameter settings, such as temperature. By adjusting these parameters and observing changes in hallucination frequency, evaluators can gain insight into model behavior.

Kyle proposed a multi-scale evaluation framework, analyzing model output across different levels: token-level (e.g., logit distributions), thought-level (e.g., prompt-response coherence), and internal model behavior. This approach can be used even with black-box models to approximate security posture.

References Worksheet

The group noted a shortage of authoritative references addressing the security implications of hyperparameters. The original submission only included basic documentation on parameter usage, rather than sources discussing vulnerabilities.

Eric committed to providing two relevant papers: one on package hallucination behaviors linked to parameter settings, and another addressing jailbreak susceptibility under varied inference configurations. Both are based on recent applied research efforts.

Observed Examples Worksheet

The group was unable to identify any specific CVEs or known incidents where insecure hyperparameter configuration was the primary cause. However, it was agreed that this weakness often appears as a secondary or adjacent factor. It may not trigger a vulnerability on its own but can exacerbate or enable other weaknesses.

This is consistent with patterns seen in other recent CWE submissions for AI systems. Kyle predicted that as AI moves into embedded, autonomous, or low-visibility applications, these misconfigurations will become more consequential.

Demonstrative Examples

In lieu of real-world cases, participants brainstormed or simulated examples to illustrate the weakness. Proposed scenarios included:

- Package hallucination leading to dependency confusion or malicious imports.
- Failures in structured outputs (e.g., malformed JSON) under unstable inference settings.
- Robotic control instability due to overly stochastic model behavior.

The JSON formatting case was preferred for its clarity and ease of demonstration. Eric offered to adapt existing data and code from prior package hallucination research into a formal demonstration for the CWE Demonstrative Examples Repository (CDR). Monica and others also suggested jailbreak and code-generation failure examples.

Next Steps

Two additional CWE topics were briefly discussed for potential future work:

1. AI model bias as a security issue (originally submitted by Kurt Seifried).
2. Input validation weaknesses in generative AI systems (submission needs reframing).

Steve noted that other MITRE work outside of ATLAS

The next working group session focused on new CWE entries is expected in about a month. A separate session on the LLM Taproot tool is likely to occur beforehand as part of ongoing CWE modification efforts.

Action Items:

- Upload two research papers related to package hallucination and jailbreak susceptibility as supporting references. (Erick)
- Create and submit a demonstrative example to the CWE Demonstrative Examples Repository (CDR) using hallucination data/code. (Erick)
- Follow up with Drew Butner regarding CWE-related proposals from recent project work. (Steve)

- Review the current draft of the CWE entry and provide feedback, particularly on detection methods and example completeness. (All)